MERROWFIELD DIGITAL

Incident Response Plan

Document Plan 01 | Rev 6 | Effective 19 January 2026 | Owner: Security Operations | Review cycle: 12 months

1. Purpose and scope

This plan governs how Merrowfield Digital detects, assesses, contains and decides on every security incident affecting its marketplace, its sellers, its customers or its staff, at all four security operations hubs: Bengaluru, Lisbon, Warsaw and Tallinn.

An incident is any event that has compromised, or may have compromised, the confidentiality, integrity or availability of Merrowfield's systems or of the data they hold. Most alerts are not incidents. An alert becomes an incident when an analyst confirms it is real.

2. Roles

Role	Responsible for
Security Analyst	Triages the incident queue, investigates incidents, establishes the facts and runs the assessment. Does not decide notification.
Data Protection Officer	Decides, under authority delegated by the board, whether an incident is recorded only, reported to a regulator, or reported to a regulator and to the customers affected.
Customer Communications Agent	Answers customers' questions about what Merrowfield does after an incident and what customers can do to protect themselves. Is told about a specific incident only once it has been disclosed to customers.

In words: the Security Analyst investigates and does not decide notification.

The Data Protection Officer decides notification under delegated authority.

The Customer Communications Agent is told about an incident only once customers have been told.

3. Severity

Every incident is given an initial severity at triage. Severity orders the desk's work; it does not decide whether an incident is reported.

Severity	Meaning
P1	Critical: customer-facing services down, or large-scale data exposure in progress
P2	High: confirmed compromise with customer data or service impact
P3	Moderate: contained compromise with limited impact
P4	Low: minor, isolated, or no impact on customers

4. When awareness begins

Two moments are recorded on every incident, and the reporting procedures count from them.

The first alert, recorded as first_alert_at, is the moment anything at Merrowfield first noticed the incident - a monitoring tool, a partner, a researcher or a member of staff.

Awareness begins when an analyst confirms that the incident is real, recorded as confirmed_at. A first alert is not awareness, and an incident awaiting confirmation has not yet reached it.

Which of the two moments a procedure counts from is written in that procedure, and nowhere else.

5. Investigation and decision are separate

The analyst who investigates an incident may not be the person who decides whether it is reported. The incident system assesses and recommends; it never decides. A decision to notify a regulator or customers is never a machine's to make.

The assessment stops and waits for the Data Protection Officer. Nothing is filed and no customer is told until the decision is recorded, with the name of the person who made it and the reason.

6. The assessment

For the incident an analyst opens, the incident system states what the analyst wants looked at, estimates the harm to the people whose data is involved, identifies the likely attack type from the analysts' notes, reads every applicable reporting procedure, estimates the effort needed to establish the facts, and writes an assessment with a recommended decision.

The harm score is the probability that the incident puts the people whose data is involved at high risk. It is banded so the desk can order its work:

A probability of 0.60 or above is band HIGH.

A probability of 0.30 up to 0.60 is band MEDIUM.

A probability below 0.30 is band LOW.

The band is an input to the decision, not the decision. The Data Protection Officer may reach a different view and records why.

7. The three decisions

Decision	What follows	Incident status
RECORD ONLY	The incident is documented. Nothing is filed and no customer is told.	RECORDED
NOTIFY REGULATOR	One filing is prepared, with a section for each applicable authority. Customers are not told.	NOTIFIED
NOTIFY REGULATOR AND CUSTOMERS	A notice to the affected customers is written first, then the filing, which states that customers were told and when.	NOTIFIED_AND_DISCLOSED

In words: RECORD ONLY documents the incident and files nothing; the status becomes RECORDED.

NOTIFY REGULATOR prepares one filing for every applicable authority; the status becomes NOTIFIED.

NOTIFY REGULATOR AND CUSTOMERS writes the customer notice, then the filing; the status becomes NOTIFIED_AND_DISCLOSED.

An incident waiting for a decision has the status PENDING_DECISION.

8. When more than one procedure applies

An incident can fall under Procedure 01, Procedure 02 and Procedure 03 at once. Which of them apply is settled from the incident's facts before any document is read: Procedure 01 when EU customers' personal data is involved and the harm band is MEDIUM or HIGH; Procedure 02 when the incident is significant; Procedure 03 when systems in India or users in India are affected.

Each applicable procedure's deadlines are then read from that procedure, and each is counted from the start that procedure names. The earliest deadline governs the work. The deadline everyone remembers is rarely the one that falls due first.

Hours remaining are measured from the moment the incident queue was extracted, as recorded on the extract, never from the clock on someone's screen, so the same incident gives the same answer to everyone who looks.

A submission is prepared to be sent no later than 30 minutes before its deadline. This is the filing reserve. The hours available for establishing the facts are the hours remaining less the filing reserve; when the estimated effort does not fit in them, an initial report is filed on what is known and completed later, as every procedure allows.

9. Campaigns

Incidents that share a campaign reference were caused by one attacker's activity - one phishing kit, one botnet, one misconfigured template. Each is still assessed and decided on its own, but for Procedure 02 the customers affected are added up across the campaign.

10. Records and audit

Every assessment, every decision, every language-model call and every document drafted is kept on the incident's record. The audit trail shows who asked for the assessment, what they asked, what was recommended, who decided, and what was filed and when.